TECHNICAL DUE DILIGENCE

Seek Wander

As-Built Architecture Review

Document Version	1.0 — Phase 3 Complete
Date	March 2026
Production URL	travel-planner-v2-pearl.vercel.app
Repository	github.com/RomaanR/travel-planner-v2
Classification	Confidential — Technical Review

This document provides a complete technical review of Seek Wander's production architecture. All systems described are live, committed, and deployed. This review covers system architecture, security controls, data schemas, cost model, and deployment topology.

01

Product Summary

Seek Wander is a luxury AI travel concierge that generates bespoke, multi-day itineraries. Users complete a 7-field intake form; the system returns a geographically-verified, chronologically-ordered day plan with restaurant recommendations, hidden gems, transit estimates, curated hotel stays, and destination photography — in 15–20 seconds.

The product is built on a **zero-hallucination data model**: every AI-generated location is enriched post-generation via Google Places API, so ratings, opening hours, and photos are ground-truthed before the user ever sees the output.

02

System Architecture

Layer Overview

Client	Next.js 14 App Router, Tailwind CSS, Framer Motion, Google Maps JS	Rendering, animation, form intake, map display
Edge/Serverless	Vercel — Next.js API Routes	Request handling, AI orchestration, enrichment pipeline
AI Engine	Anthropic claude-sonnet-4-6 (max_tokens: 8192)	Itinerary generation from structured user profile
Place Data	Google Places API (Text Search + Details)	Location verification, photos, ratings, opening hours
Auth	Clerk v6	User identity, session management, modal sign-in
Primary DB	Supabase PostgreSQL via Prisma 7	Trip storage, PlaceCache, CostLog
Rate Limiting	Upstash Redis	Sliding window rate limits per userId
PWA	@serwist/next	Service worker, offline caching, installable app
CDN/Hosting	Vercel Pro	Global edge delivery, serverless functions, cron jobs

Core Request Pipeline — POST /api/itinerary

1. Zod Validation	ItinerarySchema.safeParse() — 12 fields	400 + field errors
2. Rate Limit Check	Upstash slidingWindow(5, '1 h') per userId/IP	429 + Retry-After
3. AI Generation	claude-sonnet-4-6 with injection-resistant SYSTEM_PROMPT	Phase 4 JSON repair
4. JSON Sanitisation	sanitizeJson() regex + fallback Anthropic repair call	500 (both phases fail)
5. Place Enrichment	enrichPlace() × N — PlaceCache first, then Google Places	Graceful null (item renders)
6. Transit Calc	Haversine formula — local math, zero API calls	Never fails
7. Cost Logging	CostLog.create() awaited before Response.json()	Non-fatal try/catch

03

Technology Stack

Framework	Next.js App Router	14	TypeScript, server + client components
Styling	Tailwind CSS	v3	Custom design tokens, no border-radius
Animation	Framer Motion	12	AnimatePresence throughout
Maps	@react-google-maps/api	Latest	Places Autocomplete, Map, Polyline, Markers
AI	@anthropic-ai/sdk	^0.78	claude-sonnet-4-6, max_tokens 8192
Auth	@clerk/nextjs	v6 ONLY	v7 incompatible with Next.js 14 — do not upgrade
ORM	Prisma	7	Supabase PostgreSQL, PgBouncer pooled
Rate Limiting	@upstash/ratelimit	Latest	Sliding window, Redis-backed
Notifications	sonner	2	Branded toast layer, richColors
PWA	@serwist/next	Latest	Service worker, CacheFirst strategy
Validation	zod	4	All POST bodies, z.infer<> as source of truth

Critical version lock: @clerk/nextjs must stay at v6. Clerk v7 requires Next.js 15 and introduces breaking API changes (instead of /). Any dependency update that pulls in @clerk/nextjs@7+ will break the auth layer.

04

Security Architecture

Input Validation	Zod ItinerarySchema.safeParse() — 12 fields validated before any computation. Returns 400 with per-field fieldErrors on failure. Schema is source of truth (z.infer<>).	POST /api/itinerary
Prompt Injection Defence	SYSTEM_PROMPT passed as system: param (not in messages[]). Model instructed to ignore instructions in user fields. system param is processed at higher trust tier than messages[].	AI generation
Rate Limiting	Upstash Redis slidingWindow(5, '1 h'). Key: Clerk userId (auth) or IP (unauth). Checked before any Anthropic call — zero AI cost on rate-limited requests. Returns 429 + X-RateLimit-* headers.	POST /api/itinerary
AI JSON Self-Healing	Phase 1: sanitizeJson() strips markdown fences + trailing commas. Phase 2: JSON_REPAIR_PROMPT fallback Claude call if JSON.parse() still fails. Both failures return clean 500.	AI response parsing
HTTP Security Headers	X-Frame-Options: DENY | X-Content-Type-Options: nosniff | Referrer-Policy: strict-origin-when-cross-origin | Permissions-Policy: camera=(), microphone=(), payment=(), usb=(), geolocation=(self)	All routes
Google API Key Isolation	NEXT_PUBLIC_ key: HTTP referrer restricted to Vercel domain + localhost. MAPS_SERVER_KEY: Places API only, no referrer restriction (server-side only — never transmitted to client).	Google Places
IDOR Prevention	findUnique by ID then post-fetch trip.userId === userId check. Both missing and wrong-owner records return identical notFound(). No ownership information leaks through error differentiation.	/trips/[id]
/api/trips Auth	Returns 401 if Clerk userId absent. All queries scoped to { where: { userId } }. A user cannot retrieve another user's trip list.	GET /api/trips
Admin Neutral 404	notFound() (not redirect) for all non-admin /admin/metrics access. Prevents revealing route existence to non-admin users.	/admin/metrics
Cron Auth	Vercel injects Authorization: Bearer CRON_SECRET on every cron invocation. Route validates header — returns 401 for any other caller.	/api/cron/cleanup

05

Data Architecture

Prisma Schema

Model: Trip

id	String UUID	Primary key
userId	String	Clerk userId — no FK constraint
destination	String	Human-readable destination name
days	Int	Trip duration in days
itineraryData	Json	Full ItineraryResponse blob
createdAt	DateTime	Auto-set on create

Model: PlaceCache

id	String UUID	Primary key
cacheKey	String UNIQUE	'{name}|{city}' normalised
photoUrl	String?	Google Places photo URL
rating	Float?	Google Places rating
userRatingsTotal	Int?	Review count
hoursOpen	String?	'9:00 AM – 9:00 PM' (today's hours)
priceLevel	Int?	0–4 price scale
updatedAt	DateTime	@updatedAt — used by cron GC

Model: CostLog

userId	String?	Clerk userId — null if unauthenticated
destination	String	Trip destination
aiCost	Decimal(10,6)	Anthropic spend in USD
googleCost	Decimal(10,6)	Google Places spend in USD
totalCost	Decimal(10,6)	aiCost + googleCost

cacheHits	Int	PlaceCache hits — zero Google cost
cacheMisses	Int	Fresh Google API calls made
createdAt	DateTime	Auto-set on create

PlaceCache — Efficiency Model

Every enrichPlace() call checks PlaceCache before making any Google API call. On a cache hit (record exists and updatedAt < 30 days old):

— Zero Google API calls made

— parseOpenNow(hoursOpen, lng) computes live open/closed locally using Math.round(lng / 15) hours as UTC offset estimate (±30 min accuracy)

— Savings: $0.049 per item (Text Search $0.032 + Place Details $0.017)

— 60–80% cache hit rate typical after first weeks of operation

06

Observability & Cost Control

/admin/metrics — Internal BI Dashboard

Accessible only to the ADMIN_USER_ID Clerk userId (env var, trimmed). Non-admin access returns notFound() — route existence not leaked. Shows last 200 CostLog rows with colour-coded cost tiers.

Total Spent	SUM(totalCost) across all CostLog rows
Total Generations	COUNT(CostLog)
Avg Cost / Trip	totalSpent / totalGenerations
Cache Hit Rate	SUM(cacheHits) / SUM(cacheHits + cacheMisses)
Cost by Provider	SUM(aiCost) vs SUM(googleCost) — Claude vs Google split

Unit Economics Reference

Anthropic input tokens	$3.00 / 1M tokens
Anthropic output tokens	$15.00 / 1M tokens
Google Text Search	$0.032 / call
Google Place Details	$0.017 / call
Cache cold generation	$0.08 — $0.14
Cache warm generation (60% hits)	$0.05 — $0.09

Automated Garbage Collection

Vercel Cron runs GET /api/cron/cleanup daily at 00:00 UTC. Deletes PlaceCache rows where updatedAt < 14 days ago. The @updatedAt Prisma directive refreshes on every upsert — frequently accessed places naturally survive each cleanup cycle. CRON_SECRET bearer auth prevents external triggering.

07

Affiliate Monetization

Booking.com Integration

Affiliate ID	4013143 (Seek Wander account)
Utility	src/lib/affiliate.ts — createAffiliateUrl(hotelName, destination)
URL Pattern	booking.com/searchresults.html?ss={encoded_query}&aid;=4013143
Component	StayCard.tsx — motion.a, whileHover y:-2, ArrowUpRight CTA
Placement	ItineraryViewer — after timeline, when itinerary.recommendedStays?.length > 0
Print behaviour	print:hidden — stays excluded from PDF dossier

Accommodation Branching

CurationForm collects accommodationStatus ('needed' | 'booked') and an optional hotelName. The API route branches SYSTEM_PROMPT dynamically:

needed	Claude generates recommendedStays[] from its knowledge base	3 curated hotels with name, description, neighborhood
booked	Claude uses provided hotelName as the itinerary base	No recommendedStays[] — StayCard section absent

08

PWA & Offline Architecture

Service Worker (Serwist)

Library	@serwist/next — NOT @ducanh2912/next-pwa
Source	src/app/sw.ts → compiled to public/sw.js
Dev mode	Disabled (process.env.NODE_ENV === 'development') — no stale cache issues
CacheFirst scope	Google Places photo URLs — 30-day TTL, 100-entry cap
defaultCache	Next.js static assets: JS chunks, CSS, fonts
Manifest	src/app/manifest.ts — standalone display, Seek Wander name, brand icons

useOfflineTrips Hook — Data Strategy

Cache key	seek_wander_archive (localStorage)
Stored shape	CachedTrip[] — includes itineraryData for editorial preview
Phase 1	navigator.onLine === false → load from localStorage immediately
Phase 2	Fetch GET /api/trips (Clerk-authed) → on success: persist to cache
Fallback	Fetch failure → load from localStorage, set isOffline: true
UI indicator	Offline banner: bg-ink text-paper WifiOff icon

/api/trips — Architecture Note

Photo URLs are computed server-side in the route handler using MAPS_SERVER_KEY. The client (TripsClient.tsx) receives pre-resolved URL strings — it never holds or references the server API key. This is the correct pattern for any server-only secret that produces client-visible URLs.

09

Mobile-First Design

Responsive Layout

Mobile (< 768px)	Full-width single-column timeline	h-52 banner above timeline
Desktop (≥ 768px)	55% timeline / 45% sticky map split-screen	Sticky right panel
Print	Single-column, all days sequential	Hidden (print:hidden)

Mobile Menu — CSS Stacking Context Resolution

Problem: MobileMenu.tsx overlay appeared transparent — text from the hero background image bled through. Multiple attempts to fix via z-index, background colour, and inline styles all failed.

Root cause: Navbar.tsx applies backdrop-blur-sm to its root motion.nav element. backdrop-filter creates a new CSS stacking context. Any fixed-positioned descendant is anchored to that ancestor — not the viewport. The overlay's fixed inset-0 was anchored to the ~64px Navbar bar.

Resolution: createPortal(overlay, document.body) moves the overlay DOM node outside the Navbar tree entirely. fixed inset-0 then covers the true viewport. SSR guard: mounted state + useEffect ensures document.body is available before portal renders.

> **Architectural rule:** Any fixed full-screen overlay rendered inside a component with backdrop-filter, transform, filter, will-change, or perspective MUST use createPortal(…, document.body).

High-Contrast UI for Hero Images

Hamburger button	bg-paper border border-ink/20 rounded-full shadow-md p-3 — solid pill ensures visibility against dark photographic backgrounds
Overlay background	bg-paper (#F5F0E8) + inline style backgroundColor fallback — dual approach guarantees solid background independent of Tailwind JIT
Scroll lock	document.body.style.overflow = 'hidden' on open, 'unset' on close — useEffect cleanup reverts on unmount

10

Deployment Topology

Web App	Vercel Pro	Auto-deploy on main branch push
Database	Supabase PostgreSQL	DATABASE_URL: PgBouncer port 6543 (runtime) DIRECT_URL: port 5432 (Prisma migrations)
Auth	Clerk v6	Modal sign-in, no dedicated auth pages
Rate Limiting	Upstash Redis	REST API — stateless, no persistent connection
AI	Anthropic API	claude-sonnet-4-6, server-side only
Maps	Google Cloud	Two keys: referrer-restricted (client) + API-restricted (server)
Cron	Vercel Cron	vercel.json: '0 0 * * *' — daily PlaceCache GC
Affiliate	Booking.com	AID 4013143 — no SDK, URL-based integration

Environment Variables

ANTHROPIC_API_KEY	POST /api/itinerary	Server only
NEXT_PUBLIC_GOOGLE_MAPS_API_KEY	Browser — Maps JS, Autocomplete	HTTP referrer restricted
MAPS_SERVER_KEY	route.ts, getPlacePhoto.ts	Places API only; no referrer
NEXT_PUBLIC_CLERK_PUBLISHABLE_KEY	ClerkProvider in layout.tsx	Public
CLERK_SECRET_KEY	Clerk middleware + auth()	Server only
DATABASE_URL	Prisma runtime queries	PgBouncer port 6543
DIRECT_URL	Prisma migrations / db push	Direct port 5432
ADMIN_USER_ID	/admin/metrics auth gate	Server only; must be trimmed
CRON_SECRET	/api/cron/cleanup bearer	Server only
UPSTASH_REDIS_REST_URL	ratelimit.ts	Server only
UPSTASH_REDIS_REST_TOKEN	ratelimit.ts	Server only

Prisma Deployment Note

package.json includes postinstall: 'prisma generate' so Vercel regenerates the Prisma client with the correct Amazon Linux 2023 binary after npm install. Do NOT pin binaryTargets in schema.prisma — Prisma auto-detects the correct platform binary. Pinning to rhel-openssl-1.0.x will break on Vercel (Amazon Linux 2023 uses OpenSSL 3.x).

11

Phase Completion Audit

1 — Core Engine	Next.js + Claude + Google Maps baseline	Complete
2 — Concierge UX	7-field form, split-screen, enrichment, Haversine	Complete
3 — Ultra-Luxury UI	Tabbed nav, cost badges, transit connectors, day markers	Complete
4 — Auth	Clerk v6, conditional ClerkProvider, NavbarAuth	Complete
5 — Persistence	Prisma + Supabase, saveTrip, /trips, /trips/[id], IDOR	Complete
6 — PWA & Sharing	@serwist/next, /shared/[id] OG, ShareButton, PDF export	Complete
7 — Timeline Refactor	timeline: TimelineItem[], normalizeDayPlan() shim	Complete
8 — Margin Protection	PlaceCache, Haversine, CostLog, /admin/metrics, Cron, Zod	Complete
9 — Affiliate	Booking.com AID 4013143, StayCard, accommodation branching	Complete
10 — UX & Polish	GenerationLoader, Sonner, UnauthenticatedState, EmptyTrips, MobileMenu	Complete
11 — Mobile & Resilience	useOfflineTrips, /api/trips, Upstash, JSON repair, OG metadata	Complete
12 — Stripe Paywall	$4.99/generation after free tier — Stripe Checkout	Next